Data Security Portfolio Tasks Overview

Week and Topic	Content	Notes
1 – Threat Model	A STRIDE based threat model for university systems. You should create a model based on STRIDE that includes a data flow diagram and an explanation of the threats you are assessing	OWASP Threat Dragon might be a useful tool
2 – Authentication	Produce a design document to show your recommendation for the authentication system design based on: • Data sensitivity – what is the worst that can happen with this data? • Threats identified in your threat model (or a new threat model if you think it will help) • Practical constraints (usability, scale) – remember the usability/ security trade-off	
3 – Authorisation	Using the Univeristy data system that handles staff and student data, research data, course data and other systems you might like to consider **You are responsible for authorisation design in a university data system.** Your task is to define: • Roles • Permissions • Justified access boundaries Use **Least Privilege** as your primary design principle. Justify scope of roles, assigned permissions and demonstrate understanding of SoD	
4- Integrity and Storage	A data integrity strategy means identifying the systems to be protected, understanding the usage requirements and any legal / organisational data integrity and storage requirements and then specifying a suitable solution: • Storage solution (physical and logical) • Protection Methods (including backup and restore plan) • Integrity Verification	Very Detailed guidance in week 4 slides
5 – Logging and Auditing	Create a document explaining an auditing and logging policy for the university system	

	You should have these sections: • System context – what system is affected by the design • Data lifecycle diagram – for specific data • Audit events per lifecycle stage • Layered audit architecture diagram – each layer with relevant events • Access control to audit data – how will access be managed • Log protection strategy – stopping logs being impaired • STRIDE mapping (Tampering & Repudiation)	
6 – Data at Rest	A strategy and policy for protecting data at rest including evidence of creating and using a LUKS encrypted disk partition. • Identify sensitive data in a university system • Decide where encryption is required • Specify encryption type (disk, database, backups) – explain the selected style and method of encryption • Explain threats mitigated and remaining risks • Use the AWS Encryption Strategy guidance to help https://docs.aws.amazon.com/prescriptive-guidance/latest/strategy-data-at-rest-encryption/phases.html • Provide evidence of doing the LUKS encryption lab.	Use the Amazon policy guidance and your own research to create a policy for protecting data at rest and include with it evidence of completing the LUKS lab
7 – Data in Motion and Use	*Model the use of risk mitigation tools such as JWTs and create a Data in Motion and Use risk policy.* choose **one sensitive data type** from the university system: Examples: • grades • student records • research data • financial transactions	Detailed description in week 7 slides.

	trace the flow of the data identify: • where data is encrypted • where it is decrypted • where it is processed • where it is transmitted prepare an exposure risk table Suggest controls (such as token lifespan and refreshment) Research a topic on data in use.	